

# ביקורת מערכת מקיפה — Orly Medical

מנהל אירוע רפואי | מאי 2026

11.05.2026 | 22:28

## תקציר מנהלים

בו-זמנית. הביקורת כיסתה חמישה תחומים: אבטחה, UX ונגישות, ארכיטקטורת Backend, איכות Frontend ומוכנות לייצור. בוצעה ביקורת מקיפה של מערכת Orly Medical על ידי 5 agents מקצועיים

עם משתמשים בודדים. לפני פתיחה ללקוחות אמיתיים נדרשים תיקונים קריטיים בתחומי הגנת נתונים, ניטור שגיאות וגיבויים. ציון כולל: 3.3/10 — המערכת מתאימה כרגע לסביבת staging

סה"כ ממצאים: 72

- קריטיים: 12
- גבוהים: 18
- בינוניים: 30
- נמוכים: 12

## פרק א — ביקורת אבטחה

### ממצאים קריטיים

#### 1. ערך ברירת מחדל ל-JWT Secret

חומרה: קריטי

קובץ: backend/auth.py שורה 12

עצמו כ-fallback. כל מי שיש לו גישה ל-repository יכול לזייף JWT tokens ולהתחזות לכל משתמש במערכת, כולל אדמין. ה-SECRET\_KEY מוגדר בקוד

המלצה: הטל RuntimeError אם SECRET\_KEY לא מוגדר כמשתנה סביבה. מינימום 256 ביט אקראי.

#### 2. Token Enumeration — קצרים מדי FA קודי 2

חומרה: קריטי

קובץ: backend/routes/auth.py שורות 164, 190

הקוד משתמש ב-`secrets.token_hex(3)` — רק 16 מיליון אפשרויות. עם brute-force בקצב נמוך ניתן לנחש קוד תוך שעות. המלצה: עדכן ל-2 — `secrets.token_urlsafe(32)` בחזקת 256 אפשרויות.

## ממצאים גבוהים

### 3. Account Lockout אין

חומרה: גבוה

קובץ: backend/routes/auth.py שורות 92–106

אין נעילת חשבון לאחר ניסיונות כושלים. Rate limiting לפי IP בלבד — ניתן לעקוף עם botnets. המלצה: נעל חשבון 15 דקות לאחר 5 ניסיונות כושלים. שלח דוא"ל על ניסיון חשוד.

### 4. View Tokens בליכון בלבד

חומרה: גבוה

קובץ: backend/routes/documents.py שורה 14

של השרת. לא ניתן לביקורת ולא עמיד restart בזיכרון. הולך לאיבוד בכל Python dict הוא `_VIEW_TOKENS`. המלצה: מגרט ל-DocumentViewToken DB table עם שדות `token, expires_at, is_used, created_by`.

### 5. Family Share — אין לוג ביטול

חומרה: גבוה

קובץ: backend/routes/family\_share.py שורות 43–70

כשמבטלים קישור לבן משפחה, אין רישום מי ביטל ומתי. אין `revoked_at / revoked_by`. המלצה: הוסף שדות ביטול ל-FamilyShareToken ורשום ב-audit log.

### 6. CORS — methods פתוחים לגמרי

חומרה: גבוה

קובץ: backend/main.py שורה 106

שיטות — `allow_methods=["GET","POST","PUT","DELETE"]` ו-`allow_headers=["Content-Type","Authorization"]` HTTP פתוח לכל headers.

המלצה: רשימה מפורשת: `["GET", "POST", "PUT", "DELETE"]` ו-`["Content-Type", "Authorization"]`.

## ממצאים בינוניים

### 7. Audit Log 2 FA לא מכסה

קובץ: `backend/audit_middleware.py` שורה 14

ה-routes של `verify-2fa`, `forgot-password` ו-`reset-password` אינם מתועדים. ניסיונות התקפה לא יירשמו.

### 8. File Upload — MIME bypass אפשרי

קובץ: `backend/routes/documents.py` שורה 109

`content_type` הוא `None`, בדיקת MIME מדולגת. Magic bytes נבדק תמיד — אבל עדיף לדחות קבצים ללא `content-type`.  
אם

### 9. User-Agent — תווים ב-200

קובץ: `backend/audit_middleware.py` שורה 90

מודרני עלול להיות ארוך יותר. שנה ל-500 תווים User-Agent.

### 10. שמות env vars מטעים

קובץ: `backend/email_utils.py` שורה 6

`RESEND_API_KEY` שם לא מתאים. שנה ל — `Resend API Key` משמש ל-`SMTP_PASS`.

## פרק ב — ביקורת UX ונגישות

ציון 5/10: IS 5568 | ציון 6.5/10: WCAG AA

## ממצאים גבוהים

### 11. ניגודיות — text-slate-400 על רקע בהיר

קובץ: `PatientSummary.jsx` שורות 244, 298–300

תוכן קריטי (תאריכים, קטגוריות) בצבע אפור בהיר. WCAG AA-נמוך מ-4.5:1 — לא עומד ב-Contrast ratio.

המלצה: החלף `text-slate-500/400` ב-`text-slate-700` בכל תוכן קריטי.

## 12. כפתורים — גובה לא עקבי

קובץ: PatientSummary.jsx שורה 81

כפתור "חזרה לדף הבית" עם `py-1` בלבד — גובה `~24px`. תקן WCAG דורש `44px`.

המלצה: `[min-h-[44px]]` על כל כפתורים אינטראקטיביים.

## 13. `text-xs` תחתון

קובץ: PatientSummary.jsx שורה 859

תוויות ניווט תחתון ב-`text-xs` — קטן מדי למשתמשים עם ראייה מוגבלת.

המלצה: שנה ל-`text-sm`.

## 14. חסר במודלים RTL

קובץ: ManagerLayout.jsx ועוד

חלק מהמודלים לא מגדירים `"dir=rtl"` ב-`root` שלהם — רכיבים מקבלים כיוון LTR.

המלצה: כל `modal root` חייב `"dir=rtl"` מפורש.

## ממצאים בינוניים

## 15. `Loading States` — לא עקביים

חלק מהדפים מציגים "טוען..." כטקסט פשוט, חלקם `spinner` — אין עקביות. דרוש `Skeleton loader` מרכזי.

## 16. Keyboard Navigation

שדות תאריך (`DateSegment`), בחירות מינוי ועוד — `tab order` לא אידיאלי. `Focus outline` חסר בכמה כפתורים.

## 17. `aria-label` חסר

תקן IS 5568 דורש `aria-label` על כל שדה מורכב. `Screen reader testing` לא בוצע.

## 18. פורטל מטופל — נקודות חיוב

נכון, מצב פשוט פעיל `bottom navigation`, מוגדר, כפתור עזרה "?" פעיל, כפתור קריאה קולית פעיל `[1.8]-leading`.

# פרק ג — ביקורת ארכיטקטורת Backend

## ממצאים קריטיים

### 19. SQLite ללא WAL Mode

קובץ: backend/database.py שורות 6–12

קשה bottleneck — workers עם מספר production-בברירת מחדל חוסם קריאות בזמן כתיבה. ב SQLite

המלצה: הוסף `PRAGMA journal_mode=WAL` ב-`connect event`.

### 20. N+1 Queries משימות

קובץ: backend/routes/tasks.py שורות 51–76

= 200 meetings, workflows, requests, flags — נפרד לכל מטופל query שולחת `_sync_tasks_for_manager()`. לכל בקשה queries + עם 50 מטופלים

המלצה: שימוש ב-`joinedload()` ו-`selectinload()` מ-SQLAlchemy.

## ממצאים גבוהים

### 21. flow\_engine — שגיאות שקטות

קובץ: backend/flow\_engine.py שורות 46, 52, 91

שלושה בלוקי `except Exception: pass` — שגיאות קריטיות בחישוב כיסוי ביטוחי נבלעות בשקט.

המלצה: `logger.exception()` בכל בלוק `catch`.

### 22. APScheduler — אין max\_instances

קובץ: backend/main.py שורה 60

קודם עדיין רץ, יתחיל שני במקביל job אם `max_instances=1` ללא Weekly drug update

המלצה: הוסף `max_instances=1` לכל job.

### 23. Cascade Delete חסר בתביעות

קובץ: backend/models.py שורה 358

orphaned claims משאיר InsuranceSource מחיקת — cascade ללא Claim.insurance\_source\_id  
המלצה: הוסף "cascade="all, delete" ל-relationship.

## ממצאים בינוניים

### 24. מודל User — חסרים שדות ביקורת

אין last\_login ו-last\_activity ב-User model — קשה לזהות חשבונות לא פעילים.

### 25. Drug Search — טוען הכל לזיכרון

עם LIKE query טוענת את כל התרופות הפעילות לזיכרון בכל בקשה. עם 1,162 תרופות — בזבז זיכרון. דרוש \_search\_db() LIMIT.

### 26. Calendar Feed — Timezone hardcoded

User model-ל timezone preference קבוע בקוד. דרוש X-WR-TIMEZONE:Asia/Jerusalem

### 27. View Token TTL — 90 שניות קצר מדי

אם PDF reader פותח לאט, ה-token עלול לפוג. הגדל ל-300 שניות.

### 28. SMTP\_PASS — שם מטעה

RESEND\_API\_KEY-שנה ל — SMTP\_PASS שמור תחת Resend API Key

### 29. Migrations — Alembic ידניות

history, rollback, אין version tracking, אין Raw SQL. עם run\_migrations()

## פרק ד — ביקורת איכות Frontend

## ממצאים קריטיים

### 30. Error Boundary אין

קובץ: frontend/src/App.jsx

כלשהו זורק exception — הכל קורס. אין React. fallback UI דורש Class Component עם componentDidCatch.  
אם component

המלצה: עטוף כל ProtectedRoute ב-ErrorBoundary component.

### 31. אין 401 Token Expiry — Token Expiry שיקט

קובץ: frontend/src/main.jsx

כשה-JWT פג, בקשות נכשלות בשיקט — המשתמש לא מנותק, לא מקבל הודעה. הנתונים לא מתעדכנים.

המלצה:

```

axios.interceptors.response.use(res => res, err => {
  if (err.response?.status === 401) {
    localStorage.removeItem('token')
    window.location.href = '/'
  }
  return Promise.reject(err)
})

```

## ממצאים גבוהים

### 32. 38 מקומות של console.error ללא Toast

קבצים: ManagerDashboard.jsx, AdminPage.jsx, DoctorsDatabase.jsx ועוד

שגיאות API נרשמות ל-Console בלבד — המשתמש לא יודע שמהו נכשל.

המלצה: החלף כל `console.error(e) { catch (e) { showToast() }` ב-`showToast()`.

### 33. שמירת תרופות שקטה — IntakeWizard

קובץ: frontend/src/pages/manager/IntakeWizard.jsx שורה 662

אם שמירת תרופה נכשלת, המשתמש אינו מקבל הודעה.

## ממצאים בינוניים

### 34. formatDate — 3 קבצים

`formatDate` מכילים את אותה פונקציה PatientSummary.jsx, MyDay.jsx ו-DemoPatientPortal.jsx.

המלצה: צור `utils/formatters.js` ויצא משם.

### 35. Toast משמש בכל המקומות Toast

(ManagerDashboard, PatientDetail) קיימים ועובדים, אך לא מוטמעים בחלק מהדפים useToast ו-AppToast.

### 36. Loading States — Skeleton אין

"טוען..." כטקסט בלבד ברוב הדפים — אין skeleton loaders, אין עקביות ויזואלית.

### 37. פורטל דמו — מושלם לתצוגה

Banner. נגיש למנהל-על בלבד Demo Launcher. עם נתוני דמו מציאותיים DemoBrokerPortal ו-DemoPatientPortal. סגול ברור. כל הניווט עובד.

## פרק ה — מוכנות לייצור

ציון כולל: 3.3/10

### ממצאים קריטיים

#### 38. אין גיבוי — סיכון אובדן נתונים מוחלט

אין backup strategy. אם Railway Volume נפגע, כל נתוני המטופלים — תביעות, מסמכים, ביטוחים — אבודים לצמיתות. המלצה דחופה: job Daily backup שמעביר DB ל-S3 + Cloudflare R2. יישום מיידי.

#### 39. SQLite instances לא מתאים לריבוי —

data-זה ייגרום ל — instances יכול להוסיף Railway. קשים write locks-גורם ל threads ו-workers עם ריבוי SQLite corruption. המלצה: הגר ל-Railway PostgreSQL (Railway- PostgreSQL מציע managed PostgreSQL בחינם עד גבול).

#### 40. אין ניטור שגיאות (Sentry)

כשהשרת קורס — אין התראה. Logs אבודים לאחר 3 ימים ב-Railway. אין error traces. `pip install sentry-sdk` + ב-main.py. עלות: חינם עד 5,000 events/חודש. המלצה: `sentry_sdk.init(dsn=os.getenv("SENTRY_DSN"))`

#### 41. deploys לא בטוח להמשך — Railway Volume



אין `railway.toml` המגדיר את ה-volume כ-persistent. יכול להחליף את ה-container ולאבד נתונים.  
המלצה: הוסף `railway.toml` עם הגדרת Volume מפורשת.

## ממצאים גבוהים

### 42. CORS לא מוגדר לדומיין ייצור

הכל ייעצר, Cloudflare/CDN-עובר ל frontend אם localhost מתיר רק CORS — לא מוגדר `FRONTEND_ORIGIN`

### 43. Migrations — rollback אין

schema שנכשל חצי דרך משאיר migration. version tracking. ללא `main.py` ב-`run_migrations()`

### 44. Scheduled Jobs — Multi-Instance לא בטוחים ב

אם יש 2 instances, שניהם מריצים drug update בו זמנית — duplicates ו-race conditions.

## ממצאים בינוניים

### 45. Health Check לא בודק DB

בבדיקה DB ל-`SELECT 1` נפל. הוסף SQLite מחזיר 200 גם אם `/api/health`

### 46. Dockerfile — root רץ כ

אין `USER appuser` ב-container — Dockerfile רץ כ-root. סיכון אבטחה.

### 47. Static Files — Cache Headers אין

ביצועים ירודים. `Cache-Control: immutable` מוגשים ללא (hash בעלי) של Vite Assets

### 48. Rate Limiting — endpoints לא מכסה כל

העלאת מסמכים, חיפוש תרופות, ייצוא נתונים — ללא rate limit. מאפשר abuse.

## ציוני ביקורת

אבטחה: 5.5/10

ונגישות: UX 6.5/10

ארכיטקטורת Backend: 6/10

איכות Frontend: 6/10

מוכנות לייצור: 3.3/10

## תוכנית פעולה — 3 חודשים

### חודש 1 — ייצוב והגנת נתונים

#### שבוע 1 (דחוף ביותר)

- הגדר SECRET\_KEY חזק ב-Railway (בוצע)
- הגדר FRONTEND\_ORIGIN ב-Railway (בוצע)
- הוסף Sentry לניטור שגיאות
- יישם daily backup ל-S3

#### שבוע 2-3

- הגר ל-PostgreSQL managed
- הוסף 401 interceptor ב-frontend
- הוסף Error Boundary לכל ProtectedRoute
- החלף console.error ב-showToast

#### שבוע 4

- PostgreSQL גישור (עד SQLite ל-WAL mode)
- הוסף max\_instances ל-APScheduler jobs
- תיקון N+1 queries ב-task sync

### חודש 2 — שיפורי UX ומשתמשים

#### שבוע 5-6

- דשבורד ניהולי — סקירת כל המלווים, עומס תיקים
- מערכת התראות — דדליינים, חידוש ביטוחים
- לאחר 5 ניסיונות כושלים Account lockout

#### שבוע 7-8

- ניהול sessions — מי מחובר כרגע

- הרשאות הורדה גרנולריות
- Rate limiting על כל endpoints

## חודש 3 — פיצ'רים ו-UX

### שבוע 9-10

- עורך תבניות Workflow
- תיקוני נגישות aria-label, screen reader — IS 5568
- אחיד Skeleton loaders

### שבוע 11-12

- התראות חכמות — פערי ביטוח אוטומטיים
- וייעול ביצועים Load testing
- בדיקה עם משתמשים מעל גיל 65

## דברים שעובדים טוב

מציאותיים — מוכנים להצגה. ICS calendar feed לפי RFC 5545. מערכת תרופות עם 1,162 תרופות ו-842 שמות עבריים. כפתור עזרה, קריאה קולית ומצב פשוט — מוכן לאוכלוסיה מבוגרת. Demo portals לפורטל מטופל ולברוקר עם נתוני דמו קריטיים. security headers (X-Frame-Options, HSTS, Referrer-Policy) פעילים. פורטל מטופל עם 1.8-leading, parameterized queries — אין SQL injection. Audit middleware מיירט 17 סוגי פעולות. Rate limiting מוגדר על endpoints עם SQLAlchemy, 2FA (TOTP + Email + WebAuthn), bcrypt עם JWT, stack מודרני ויציב. JWT עם 2FA (TOTP + Email + WebAuthn), bcrypt עם JWT, stack מודרני ויציב. המערכת בנויה על